

Security Metrics & Architecture Governance

Why metrics

Security teams shop with vague "we're more secure now." Metrics translate effort into business language: risk reduced, breaches avoided, coverage increased.

Good metrics

Category	Example metric
Coverage	% of assets with EDR, % of apps with secrets scanning
Speed	Mean time to patch critical (MTTC), time to provision restricted server
Quality	% of findings remediated within SLA, vuln-age profile
Detection	Mean time to detect (MTTD) and respond (MTTR)
Adoption	Phishing simulation failure rate, training completion

Guard against gaming

- Vanity metrics (total alerts) don't drive decisions
- Track the metric + the action it should trigger
- Baseline, then trend: "mean time to patch dropped 3 days quarter-over-quarter"
- Pair lagging (outcome) with leading (input) indicators

Architecture governance

Constrained "wild west" architecture never stays secure:

- Architecture Review Board (ARB) gates design changes

Policy-as-code – IaC checks (e.g., deny world-readable S3) enforced in CI

Reference architectures for common patterns

Exception process – deviation is recorded, dated, owned, and re-reviewed

The security scorecard

A CISO-grade report:

Control maturity: 72/100 (baseline 60)
Critical vuln exposure: 14 (target <5) - trend down
Mean time to patch critical: 9 days (SLA 7) - MISS
EDR coverage: 96%
User susceptibility rate: 11% (target <10)

Metrics only matter when they change decisions. If a metric does not influence budget, priority, or architecture gate – it is decoration.

[← Threat Modeling in Practice:...](#)

Module complete ✓